Compte-Rendu de TP : Sécurisation Linux (TP3)

Mise en place du pare-feu Firewalld, durcissement du service SSH et surveillance avec Journald & Auditd.

TP : TP3 - Pare-feu, SSH & Journaux	**Machine cible :** Rocky Linux 9 (srv-core)
Machine distante : srv-edge (192.168.56.11)	**Contexte :** Audit Cyber Hélios Logistique

1. En bref : Comment j'ai réalisé les exercices

L'objectif de ce TP était d'éliminer les vulnérabilités majeures constatées sur `srv-core` (pare-feu coupé, SSH ouvert à tous sur le port 22 par mot de passe, aucun journal conservé au redémarrage).

Étape 1 : Segmentation avec Firewalld (Mission 1)

- J'ai réactivé `firewalld` et associé chaque interface réseau à sa zone dédiée via NetworkManager (`nmcli`).
- J'ai défini la zone par défaut sur `drop` (tout bloquer) et fermé les services inutiles (Cockpit, Samba, DHCPv6).
- J'ai ajouté des **règles riches** pour limiter le nombre de connexions SSH (maximum 6 par minute), journaliser les tentatives (prefix `SSH-NEW`) et créer une liste de blocage automatique (`helios-blacklist` via ipset).

Étape 2 : Durcissement du serveur SSH (Mission 2)

- J'ai d'abord généré et copié une clé SSH Ed25519 depuis `srv-edge` vers le compte `sysops` pour éviter de me faire enfermer dehors.
- J'ai créé un fichier de configuration `/etc/ssh/sshd_config.d/10-helios-hardening.conf` pour :
  - Changer le port par défaut (passé de `22` à `2242`).
  - Désactiver la connexion du compte `root` et interdire l'authentification par mot de passe.
  - Restreindre l'accès aux membres du groupe `ssh-admins` uniquement.
- J'ai mis à jour SELinux (`semanage port -a -t ssh_port_t -p tcp 2242`) et le pare-feu pour autoriser le nouveau port.
- J'ai renforcé les algorithmes de chiffrement autorisés via la politique système (`update-crypto-policies`) et un fichier dédié.

Étape 3 : Journaux persistant et audit (Mission 3)

- J'ai rendu `journald` persistant dans `/etc/systemd/journald.conf.d/50-helios.conf` avec une limite de taille à 500 Mo et 1 mois de conservation.
- J'ai configuré `auditd` avec le fichier `90-helios.rules` pour surveiller les fichiers critiques (`/etc/passwd` , `/etc/sudoers` , etc.) et tracer l'utilisation des commandes root.
- J'ai créé un script Bash (`helios-watch-auth.sh`) associé à un timer Systemd exécuté toutes les 2 minutes pour bannir automatiquement dans l'ipset toute adresse IP qui échoue plus de 5 fois à s'authentifier.

2. Difficultés rencontrées et Solutions trouvées

1. Le changement de port SSH bloquait le redémarrage de SSH

Problème : En passant le port de SSH à `2242` dans `sshd_config`, le service SSH refusait de démarrer et affichait une erreur d'accès refusé.

Explication : Sur Rocky Linux 9, SELinux bloque par défaut l'écoute de SSH sur des ports non standard.

Solution : J'ai déclaré le port 2242 dans SELinux avec la commande `semanage port -a -t ssh_port_t -p tcp 2242` avant de relancer `sshd`.

2. L'option Ciphers dans SSH n'était pas prise en compte

Problème : Même après avoir ajouté mes algorithmes de chiffrement dans `10-helios-hardening.conf`, `sshd -T` continuait d'afficher les anciens algorithmes.

Explication : Sur RHEL/Rocky 9, le fichier `50-redhat.conf` est chargé au début de la configuration et applique les *crypto-policies* globales. De plus, j'avais mis les directives sous un bloc `Match Group` qui bloquait leur prise en compte.

Solution : J'ai créé un fichier `05-helios-crypto.conf` (lu *avant* `50-redhat.conf`) et mis à jour la politique globale du système avec `update-crypto-policies --set DEFAULT:NO-SHA1`.

3. Blocage de l'administrateur par le script de bannissement automatique

Problème : Lors des tests d'attaque depuis `srv-edge`, l'IP 192.168.56.11 s'est retrouvée bloquée dans l'ipset `helios-blacklist`. Quand j'ai retiré manuellement l'IP, le timer Systemd la rebloquait aussitôt à l'exécution suivante.

Explication : Le script analysait les journaux sur une fenêtre de 10 minutes. Tant que les 5 échecs restaient dans la fenêtre de temps du journal, le script réappliquait le blocage.

Solution : J'ai arrêté temporairement le timer (`systemctl stop helios-watch-auth.timer`), débloqué l'IP, puis reprogrammé le timer pour qu'il ne reprenne qu'après l'expiration de la fenêtre de 10 minutes.

3. Tableau d'affectation des interfaces par zone Pare-feu

Interface	Connexion NM	Zone Firewalld	Politique et services autorisés
`enp0s3`	NAT / Internet	`drop`	Aucun accès entrant accepté. Tout est jeté silencieusement.
`enp0s8`	admin	`work`	SSH (port 2242) avec rate-limiting (6/min max), IPset blacklist.
`bond0`	bond0 (métier)	`internal`	SSH (port 2242) + Supervision Zabbix (port 10051/tcp).
`bond0.42`	bond0.42 (VLAN)	`internal`	Idem zone internal (accès réservé aux équipes métiers).

4. Résultat des 7 tests de validation SSH depuis `srv-edge`

#	Commande / Test	Résultat attendu	Résultat observé
1	`nc -zv 192.168.56.10 22`	Échec (Port 22 fermé)	Connection refused (OK)
2	`ssh -p 2242 sysops@...` (avec clé)	Connexion réussie	Accès shell accordé (OK)
3	`ssh -p 2242 root@...`	Refusé	Permission denied (publickey) (OK)
4	Tentative par mot de passe	Refusé	Option mot de passe absente (OK)
5	`ssh -p 2242 nadia@...`	Refusé (Hors ssh-admins)	Permission denied (OK)
6	Tunnel TCP port 10051 (helios-ops)	Autorisé uniquement à l'usage	Connexion établie sur 127.0.0.1:9999 (OK)
7	Connexion avec KEX SHA-1 obsolète	Refusé par la crypto policy	no matching key exchange algorithm (OK)